SOC·DESK

The analyst's first stop for any indicator.

A free, public, static threat-intelligence console for a T1/T2 SOC analyst. Paste an IP, hash, URL, domain, CVE or email and get one screen back: a verdict grounded in public reputation and vulnerability data, a ticket-ready escalation write-up, and one-click pivots to the services worth checking. Zero infrastructure, zero cost, zero accounts.

> **Positioning.** The heavyweight open-source CTI platforms (OpenCTI, MISP, IntelOwl) need servers and databases. SOCDesk sits deliberately beneath them: the zero-infra, public-URL, analyst-speed layer an analyst actually opens mid-shift.

OPERATING PRINCIPLES — CONSTANT ACROSS EVERY LEG

— **$0, free-tier only.** No paid infra, no paid APIs beyond free community tiers.

— **No-infrastructure.** Static site + Cloudflare Pages Functions. No database, no server to run.

— **Aggregator, not mirror.** Publish only clearly-redistributable data; reputation corpora are reached by user-clicked links, never held.

— **No secrets in the repo.** Collectors are keyless; enrichment keys live server-side in Cloudflare, never in git or the browser.

— **Privacy by default.** Analyst state (reviewed, watchlist, notable) is localStorage only. No accounts, no analytics, no tracking.

— **Strict CSP + defence in depth.** `default-src 'none'`, no inline script; every upstream string sanitised at collection and escaped again at render.

— **RADAR visual direction.** Dark warm-espresso / warm-paper, search-first, periwinkle accent + SD monogram; distinctive, not AI-slop. Now rebuilt on Vite + React + Tailwind + Motion (strict CSP kept) for an AAA craft ceiling — the live site still serves the vanilla build; the React build is staged for deploy. (Chart Room superseded.)

LEG 1 · CURRENT SPRINT

01 INDICATOR LOOKUP & ESCALATION

CORE · LIVE

The 99% workflow: paste an indicator → live reputation verdict → screenshot-grade evidence card → paste into the escalation email. This Leg is the product.

INPUT & DETECTION

- ✓ **Omnibox** with type auto-detect + refang `(evil[.]com, hxxp)`
- ✓ **Bulk lookup** — many indicators, one table, CSV/JSON/defanged export
- ✓ **Bookmarklet** — fire a lookup from any page
- ✓ **Shareable #q= deep links** — "look at this" is a URL

LIVE ENRICHMENT · /API/ENRICH

- ✓ **IP** → AbuseIPDB · VirusTotal · GreyNoise · **ipinfo** geo/ASN
- ✓ **Hash** → VirusTotal · MalwareBazaar
- ✓ **URL / domain** → VirusTotal · **urlscan** verdict + screenshot
- ✓ **Consensus tally** — "N of M sources flagged"; SOCDesk counts, never asserts a verdict

OUTPUT — THE DIFFERENTIATOR

- ✓ **Escalation card** — copied into the ticket as a PNG image (Copy card) or text; no SOCDesk recommendation (the analyst's call)
- ✓ **Type-aware pivots**, trimmed to the T1 workflow set (no fluff vendors)
- ✓ **CVE** — authoritative, attributed: CISA-confirmed exploited (KEV) + CVSS + EPSS
- ✓ Honest states — "0 of M flagged" is never dressed as a clearance

REACH — THE RECORDED-FUTURE MOVE

- ✓ **Browser extension** — own React/MV3 build reusing the web escalation cards via a shared package; right-click lookup + popup over the live API. Final parity QA (load unpacked → context-menu handoff) pending
- ○ **v2 · inline page annotation** — highlight indicators on any page `(broad perms — later)`
- ○ **Bookmarklet selection-capture** — no-install fallback

LIVE at socdesk.io (vanilla build). Built in-tree, staged for deploy: the AAA React rebuild (web/ — Overview, Lookup, Data Desk, Gallery routes; three.js globe hero with a real light mode; per-entity escalation cards) and the extension parity uplift (shared card package, own MV3 build). Deploy flip site/ → web/ is gated. Verdict output is the consensus tally — see docs/VERDICT-LANGUAGE.md.

LEG 2 · NEXT CORE FUNCTION

02 THREAT INTELLIGENCE FEED

CORE · EVOLVE, DON'T REBUILD

Situational awareness for the shift: what's happening, what's exploited, what's relevant to us. The pipeline is already strong and tested — Leg 2 is additive, not a rewrite.

ALREADY BUILT (THE FOUNDATION)

- ✓ **Collector pipeline** — KEV, NVD, EPSS, Ransomware.live, RSS pool; fault-isolated, schema-gated with last-known-good
- ✓ **CVE triage** — full KEV catalogue joined with CVSS + EPSS, risk-sorted
- ✓ **Feed work-queue** — explainable relevance scoring, claim grouping
- ✓ **ATT&CK actor/malware profiles** + **RELATED** entity index
- ✓ Collection health, source registry, trends

PLANNED EVOLUTION (ADDITIVE)

- ○ **AI Daily Brief** — Framework local LLM writes the shift brief `(passthrough already wired)`
- ○ **Client / sector relevance** — "affects our clients" filter, the MSSP differentiator
- ○ **Wave-2 collectors** — FeodoTracker, C2IntelFeeds, PhishTank, APTnotes
- ○ **Push / alerting** — shift digest to Slack/email
- ○ **Decouple data-refresh from site-deploy** for higher cadence

DESIGN DECISIONS TO LOCK FIRST

- What the feed is *for* (brief vs. relevance-filter vs. hunt-feed)
- Data backbone (static vs. KV/R2) · watchlist location · alerting scope

Approach: a proper design pass before building, on top of the existing pipeline. The early "garbage" was the UI/identity — long since fixed — not the data layer.

LEG 3 · FUTURE

03 LIVE ATTACK SENSOR — KNOCKKNOCK.NET-STYLE

FUTURE · GATED

SOCDesk stops being only an aggregator and starts producing first-party intelligence: our own honeypot sensors observing real attacks, published as a live feed that loops back into Legs 1 & 2.

CORE FUNCTIONS

- ○ **Own honeypot sensor(s)** — Cowrie-class, capturing live SSH/Telnet/scan activity
- ○ **Live attack telemetry & globe visualisation** `(mockup: design/mockups/h-sensor.html)`
- ○ **First-party IOC feed** — observed attacker infrastructure, feeding Leg-1 verdicts and Leg-2 feed
- ○ Trend surfacing — emerging scan campaigns, credential-spray patterns

SECURITY NON-NEGOTIABLES

- — **No Tailscale on the sensor** — no path from the honeypot into the tailnet
- — **Cloud-plane egress deny** by default
- — **Publish /24s, not full IPs** — no doxxing of compromised hosts
- — **Allowlist published tokens**; rebuild from cloud-init, never snapshots

GATE

- ▸ Resolve the **employer-IP-assignment question** first — it gates this Leg (and the repo-private decision)

SEQUENCING & CURRENT STATUS

- ✓ **Done:** Leg 1 is LIVE at socdesk.io — multi-source enrichment, the consensus tally, live /api/enrich. AAA rebuild built in-tree: Vite + React + Tailwind + Motion under strict CSP (phases 1–4 + site effects), a three.js globe hero with a real light mode, per-entity escalation cards, and extension parity (shared card package + own MV3 build, phases 0–2). Spec: docs/superpowers/specs/2026-08-12-aaa-modern-stack-design.md.
- ▸ **Now:** Overview board rework (per-lane selection over the score-sort artifact; ransomware-activity leaderboard + named-actor lane; de-LARP voice), then the deploy flip site/ → web/ (gated), then extension final parity QA in Chrome.
- ○ **Then:** settle the employer-IP question → repo public vs. private; Leg 2 threat-intel feed on the existing pipeline (dedup + prioritisation first, then scale article volume).
- ○ **Later:** Leg 3 sensor, once the IP gate clears.